

- [Checklist de Seguridad - Finanzas AGV](#)
 - [1. Autenticación y control de acceso](#)
 - [2. URLs y rutas](#)
 - [3. Sesión y cookies](#)
 - [4. Secretos y configuración](#)
 - [5. API y datos](#)
 - [6. Módulos y blueprints](#)
 - [Uso del checklist](#)
 - [Referencia rápida en este proyecto](#)

Checklist de Seguridad - Finanzas AGV

Estándar de revisión para garantizar que la aplicación cumpla requisitos mínimos de seguridad antes de despliegue y en auditorías (jefatura de proyectos, QA).

1. Autenticación y control de acceso

#	Revisión	Estado
	Todos los módulos exigen sesión: Ninguna ruta de negocio	
1.1	(letras, cobranzas, exportaciones, etc.) es accesible sin <code>@require_login</code> en backend.	☐
	Frontend coherente: Todas las páginas protegidas (no solo	
1.2	<code>/login</code>) validan sesión al cargar (ej. <code>authApi.getUserInfo()</code>) y redirigen a <code>/login</code> si hay 401.	☐
1.3	Cerrar sesión disponible en toda la app: El botón "Cerrar sesión" está en un lugar común (ej. Sidebar o layout), no solo en un módulo.	☐
1.4	Ruta raíz: La ruta <code>/</code> redirige a <code>/login</code> o a una pantalla que a su vez exige autenticación.	☐
1.5	APIs sensibles: Endpoints de export (Excel, PDF) están protegidos con el mismo mecanismo que los reportes.	☐

2. URLs y rutas

#	Revisión	Estado
2.1	Rutas de desarrollo bloqueadas en producción: URLs o módulos solo para desarrollo están deshabilitados o devuelven 403 en producción (ej. <code>RESTRICT_TO_LETTERS_ONLY</code> o lista de prefijos permitidos).	☐
2.2	Acceso por URL directa: Entrar a una URL protegida (ej. <code>/collections</code>) sin sesión debe terminar en redirección a login, no en mostrar datos.	☐
2.3	Health check público: Solo endpoints explícitamente públicos (ej. <code>/api/health</code>) son accesibles sin autenticación.	☐

3. Sesión y cookies

#	Revisión	Estado
3.1	Cookie de sesión: Nombre específico (ej. <code>finanzas_agv_session</code>), no el default de Flask.	☐
3.2	Producción: <code>SESSION_COOKIE_SECURE=True</code> , <code>SameSite</code> adecuado para tu dominio (ej. <code>None</code> si hay cross-site con frontend en otro dominio).	☐
3.3	Cierre de sesión: <code>logout</code> limpia la sesión en backend (<code>session.clear()</code>) y redirige al login.	☐

4. Secretos y configuración

#	Revisión	Estado
4.1	**<code>.env</code> en <code>.gitignore</code>**: Archivos con credenciales (<code>.env</code> , <code>.env.desarrollo</code> , <code>.env.produccion</code>) no se suben al repositorio.	☐

#	Revisión	Estado
4.2	Sin secretos en código: No hay contraseñas, API keys ni tokens hardcoded en el código fuente.	☐
4.3	Variables de entorno: Uso de <code>os.getenv()</code> o equivalente para Odoo, Supabase, mail, etc.	☐

5. API y datos

#	Revisión	Estado
5.1	Respuesta 401 en no autenticado: Los endpoints protegidos devuelven 401 (y mensaje claro) cuando no hay sesión válida.	☐
5.2	CORS: Origen permitido configurado según entorno (frontend URL en producción).	☐
5.3	Errores sin filtrar: En producción no se exponen stack traces ni rutas internas al usuario; logs sí pueden tener detalle.	☐

6. Módulos y blueprints

#	Revisión	Estado
6.1	Inventario de rutas: Lista de blueprints y rutas; cada ruta de negocio marcada como protegida o pública.	☐
6.2	Nuevos módulos: Al agregar un nuevo blueprint (ej. treasury, deductions), aplicar <code>@require_login</code> por defecto y documentar excepciones.	☐

Uso del checklist

- **Antes de ir a producción:** Completar todas las casillas y corregir los ítems no cumplidos.

- **En reuniones de seguridad/QA:** Usar como referencia para demostrar qué se revisa y qué está cubierto.
 - **Después de agregar funcionalidad:** Revisar al menos la sección 1 y 6.
-

Referencia rápida en este proyecto

- **Auth:** `app/auth/security.py` — decorador `require_login`.
- **Backend protegido:** Letras ya usa `@require_login` en todas sus rutas; Cobranzas y Exports deben usar el mismo patrón.
- **Frontend:** Página Letras valida sesión y redirige a `/login`; la página Cobranzas debe replicar esa validación.
- **Cerrar sesión:** Debe estar en un componente compartido (Sidebar o layout), no solo en una página.